

LUMINA ENERGY · HELIOS PLATFORM

Compliance & Regulatory Requirements

CLASSIFICATION: INTERNAL — RESTRICTED

Owner: Yasmin Osei (Security Lead) + Priya Nair (Platform Engineering) | Legal Liaison: Emma Hartley (Senior Legal Counsel) | Last Updated: 2024-11-05 | Last Legal Review: 2024-09-12

1. Regulatory Landscape — Current Compliance Status

FRAMEWORK	APPLICABILITY	STATUS	LAST ASSESSED
UK GDPR	UK customers + data processing	✓ Compliant (gaps—see §2)	Sep 2024
EU GDPR	EU customers	✓ Compliant (gaps—see §2)	Sep 2024
OFGEM Network Security	UK electricity network operators	✓ Compliant	Nov 2024
BDEW/BSI IT Security Cat.	German energy operators	✓ Compliant	Aug 2024
NIS2 Directive	EU critical infrastructure	■ In Progress	Oct 2024
ISO 27001	Voluntary (required by some customers)	■ In Progress (target Q2 2025)	—
SOC 2 Type II	Voluntary (required by US customers)	■ In Progress (target Q3 2025)	—
AEMO Cybersecurity	Australian market operator	✓ Compliant	Jun 2024
NERC CIP	US critical infrastructure (pending launch)	■ Planning	—

2. GDPR Compliance

Data Subject Rights Implementation

RIGHT	MECHANISM	STATUS	SLA
Right of Access (SAR)	Manual — #privacy-requests Slack → Emma Hartley	✓ Implemented	30 days
Right to Erasure	Partially manual — see gap note below	■ GAP	30 days
Right to Rectification	Via customer API + manual for account data	✓ Implemented	30 days
Right to Portability	Data export API (JSON/CSV)	✓ Implemented	30 days
Right to Object	Manual process	✓ Implemented	30 days
Right to Restrict Processing	Manual process	✓ Implemented	30 days

GDPR Gap — Right to Erasure: TimescaleDB holds meter telemetry in weekly partitions containing mixed customer data. Deleting a single meter's records requires a full table scan (~8–15 min per meter). A manual script (gdpr-meter-erasure.sql) exists but is not productionised. Rosa Lindqvist runs it manually for the ~2–4 erasure requests per month. Automated solution in Q1 2025 roadmap (GDPR-GAP-001).

3. Energy Sector Regulation Summary

JURISDICTION	REGULATION	KEY REQUIREMENT	STATUS
UK	OFGEM Network Security Guidelines	Availability SLAs, 4-hr incident notification for >15,000 consumers, annual security review	Compliant
Germany	BDEW/BSI IT Security Catalogue	Critical patch SLA, MFA, coordinated vulnerability disclosure	Compliant
Australia	AEMO Cybersecurity Framework	Cloud data residency (ap-southeast-2), AEMO market rule compliance, monthly performance review	Compliant
USA (planned)	NERC CIP	CIP-008-6 cyber incident response, CIP-011 info protection	Not Applicable at US customer go-live

4. NIS2 Directive — Gap Status (October 2024)

OBLIGATION	STATUS	OWNER	TARGET
Cybersecurity risk management measures	■ In Progress	Yasmin Osei	Q1 2025
Incident reporting (<24h initial, <72h full)	■ Process being documented	Emma Hartley	Q1 2025
Supply chain security measures	■ In Progress	Yasmin Osei	Q2 2025
Cyber hygiene and security training	✓ Annual training in place	Yasmin Osei	Ongoing
Management accountability (designated officer)	✓ Elena Vasquez designated	—	Done
Business continuity (DR plan)	✓ DR plan in place	Marcus Webb	Done

5. Data Retention Schedule

DATA TYPE	RETENTION	LEGAL BASIS	DISPOSAL METHOD
Grid telemetry (raw)	7 years	OFGEM regulatory	Automated TimescaleDB retention policy
Grid telemetry (hourly agg.)	15 years	Regulatory + commercial	Manual disposal after period
Customer account data	Contract + 6 years	Contract + limitation	Automated offboarding process
Security audit logs	7 years	OFGEM, NIS2	Immutable S3 WORM — no deletion
Application logs (non-audit)	90 days	Operational	Automatic Elasticsearch expiry
Kafka topic data (raw)	7 days	Operational	Automatic Kafka retention
Aurora backup snapshots	35 days	Operational	AWS automated deletion

6. Regulatory Notification Deadlines

JURISDICTION	TRIGGER	DEADLINE	NOTIFIED BODY
UK	>15,000 consumers affected OR grid safety risk	4 hours	OFGEM + NCSC
Germany	Security incident affecting critical infrastructure	2 hours	BSI
Australia	Market-affecting outage detection failure	Immediate	AEMO
EU (NIS2)	Significant cybersecurity incident	24h initial / 72h full	National CSIRT
All	Personal data breach affecting EU/UK persons	72 hours	ICO (UK) / Lead SA (EU)

IMPORTANT: Engineers must NEVER contact regulators directly. All regulatory notifications go through Emma Hartley (Legal). In an incident, page Yasmin Osei immediately — she coordinates with Legal.

7. Compliance Roadmap

QUARTER	MILESTONE	OWNER
Q1 2025	NIS2 incident reporting procedures documented	Emma Hartley
Q1 2025	GDPR right-to-erasure automation completed	Rosa Lindqvist
Q2 2025	ISO 27001 certification audit	Yasmin Osei
Q3 2025	SOC 2 Type II report published	Yasmin Osei
Q3 2025	NERC CIP readiness (pre-US launch)	TBD
Q4 2025	NIS2 full compliance	Yasmin Osei